

AZURE PRIVILEGED ACCESS & SECRETS MANAGEMENT LAB

Managed Identity • RBAC • Key Vault • Automation • KQL • Azure Monitor

Portfolio Case Study

Cordarrel Wilson
Buffalo, NY

Project focus: Secure workload authentication, least-privilege authorization, secret lifecycle management, centralized auditing, and detection of unauthorized Key Vault activity.

1. Summary

This project implements an Azure secrets-management workflow in which an Azure Automation runbook authenticates with a Microsoft Entra managed identity and retrieves a protected secret from Azure Key Vault. No reusable credential is stored in the runbook, and the secret value is intentionally excluded from job output.

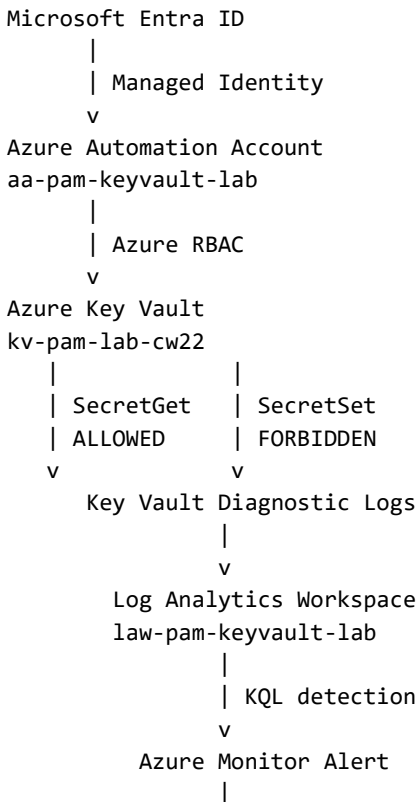
Azure RBAC is used to enforce least privilege. The automation managed identity receives the Key Vault Secrets User role at the vault scope, allowing secret retrieval while preventing secret creation or modification. The authorization boundary was validated with positive and negative tests: SecretGet succeeded, while SecretSet returned Forbidden.

Key Vault diagnostic events are centralized in Log Analytics, investigated with KQL, and used by Azure Monitor alerting. The lab also validates secret version rotation without requiring a runbook code change.

2. Project Objectives

- Eliminate hard-coded credentials from automation by using a managed identity.
- Protect application credentials in Azure Key Vault.
- Enforce least privilege with vault-scoped Azure RBAC.
- Validate that authorized reads succeed while unauthorized writes fail.
- Rotate a secret using Key Vault versioning without changing application logic.
- Centralize Key Vault audit events in Log Analytics and query them with KQL.
- Generate Azure Monitor alerts for selected unauthorized Key Vault activity.

3. Architecture



4. Technologies Used

Technology	Purpose
Microsoft Entra ID	Workload identity and authentication
Azure Key Vault	Secret storage, versioning, and access control
Azure Automation	PowerShell-based secret retrieval and authorization testing
Azure RBAC	Least-privilege authorization
Managed Identity	Passwordless authentication from Automation to Azure
Log Analytics	Centralized Key Vault audit telemetry
KQL	Security investigation and detection queries
Azure Monitor	Alert rule evaluation and notification

5. Implementation & Validation

5.1 Key Vault and RBAC

The lab uses Key Vault kv-pam-lab-cw22. The Azure Automation managed identity is assigned Key Vault Secrets User at the vault scope. Administrative secret-management access is kept separate from the workload identity.

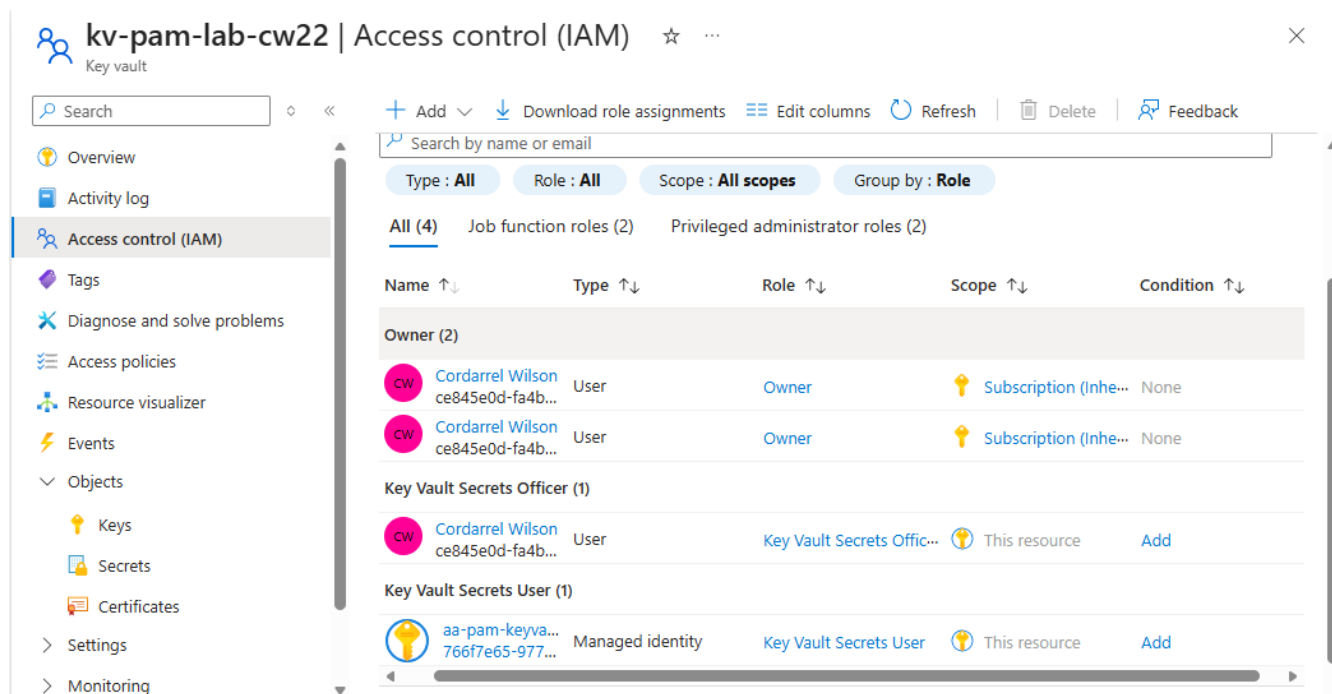


Figure 1. Vault-scoped RBAC showing the managed identity as Key Vault Secrets User.

5.2 Secure Secret Retrieval

The Get-KeyVaultSecret runbook authenticates using the Automation Account managed identity. It retrieves Database-Password while logging only a success message and the secret name; the secret value itself is not written to job output.

```
Completed

Mode          : Process
ContextDirectory :
ContextFile    :
CacheDirectory :
CacheFile      :
KeyStoreFile   :
Settings      : {}

Managed Identity authentication successful.
Secret retrieval successful.
Secret Name: Database-Password
Secret value was retrieved securely and was not written to logs.
```

Figure 2. Successful managed-identity authentication and secret retrieval.

5.3 Least-Privilege Negative Test

A separate test runbook attempted to create or modify a Key Vault secret using the same managed identity. The request was rejected with Forbidden, confirming that the workload's read permission did not implicitly grant secret-management privileges.

Test ...

Test-LeastPrivilege

Start

Stop

Suspend

Resume

View last test

Refresh job streams

Parameters

No parameters

Run Settings

Run on

Azure

Activity-level tracing

This configuration is available only for graphical runbooks.

Trace level

None

Basic

Detailed

Completed

Mode : Process
ContextDirectory :
ContextFile :
CacheDirectory :
CacheFile :
KeyStoreFile :
Settings : {}

Environments

{{[AzureUSGovernment, AzureUSGovernment]}, [AzureCloud, AzureCloud]}, [AzureChinaCloud, AzureChinaCloud]} Microsoft.Azure...

Managed Identity authentication successful.
EXPECTED DENIAL
Managed Identity cannot create or modify Key Vault secrets.
Least-privilege control verified.
Error: Operation returned an invalid status code 'Forbidden'
Code: Forbidden

Figure 3. Expected SecretSet denial proving the least-privilege boundary.

5.4 Audit Verification with KQL

Key Vault diagnostic logs were sent to Log Analytics. The audit trail showed denied SecretSet operations with ResultSignature = Forbidden, providing independent evidence of the authorization failure.

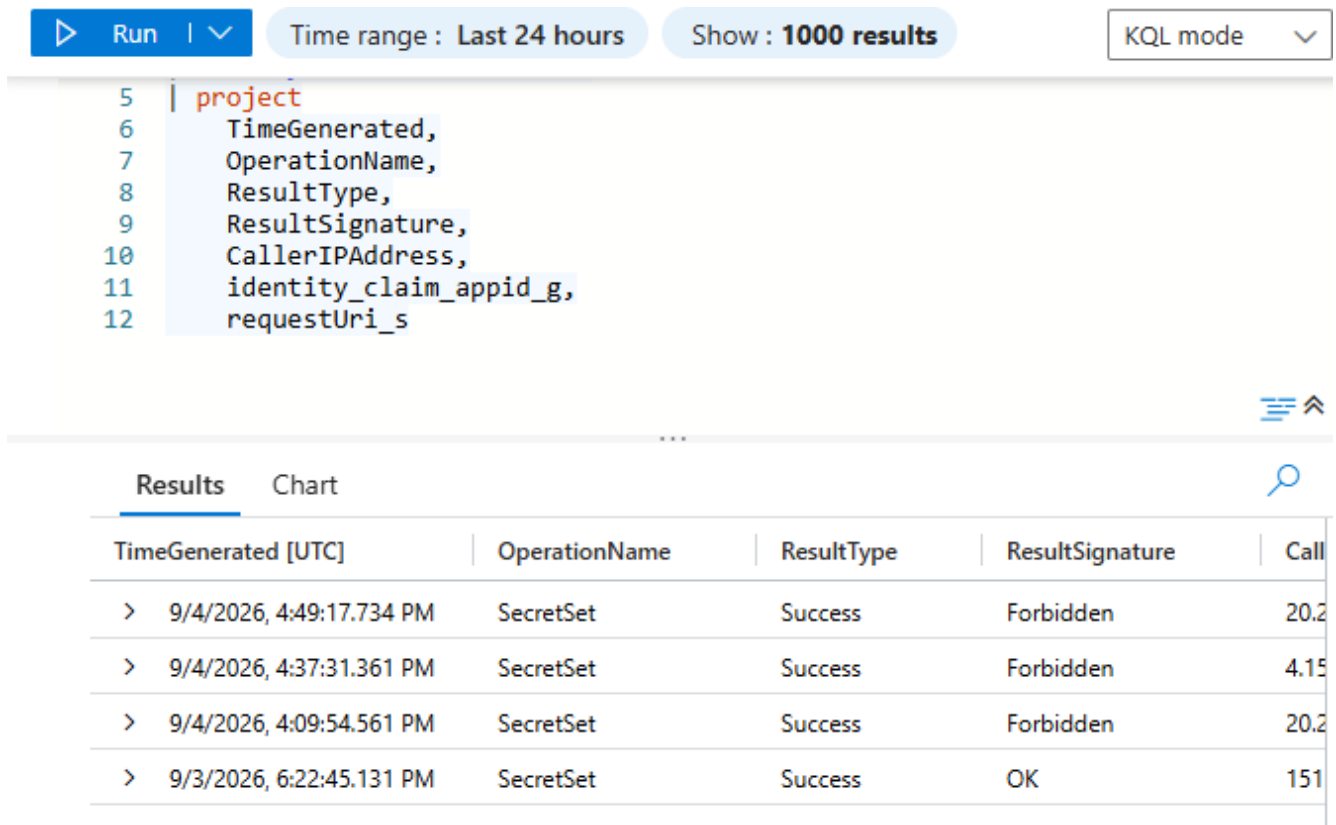


Figure 4. Log Analytics evidence of denied SecretSet operations.

5.5 Monitoring and Alerting

An Azure Monitor log-search alert was configured against Key Vault diagnostic data. A controlled unauthorized-access test generated a fired informational alert, demonstrating the detection path from Key Vault telemetry through Log Analytics to Azure Monitor.

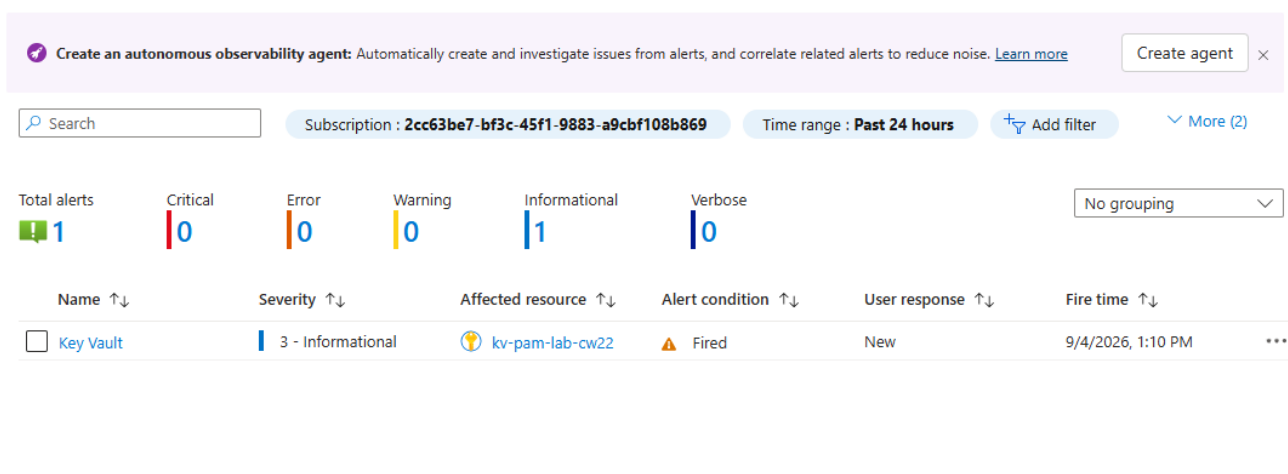


Figure 5. Azure Monitor Key Vault alert in Fired state.

6. Secret Rotation

Database-Password was rotated by creating a new Key Vault secret version. The existing runbook was then executed without changing its code and successfully retrieved the current secret. This demonstrated decoupling between application logic and the credential value.

7. Example Detection Query

```
AzureDiagnostics
| where ResourceProvider == "MICROSOFT.KEYVAULT"
| where OperationName == "SecretSet"
| sort by TimeGenerated desc
| project TimeGenerated,
           OperationName,
           ResultType,
           ResultSignature,
           CallerIPAddress,
           identity_claim_appid_g,
           requestUri_s
```

8. Security Controls Demonstrated

Control	Implementation
Passwordless workload authentication	Managed Identity
Centralized secret storage	Azure Key Vault
Least privilege	Key Vault Secrets User for the workload
Separation of duties	Administrative and workload permissions separated
Credential lifecycle	Secret version rotation
Auditability	Key Vault diagnostic logs
Detection	KQL over centralized logs
Response visibility	Azure Monitor alert and action group notification

9. Key Results

- Managed identity authenticated successfully without a stored service credential.
- SecretGet for Database-Password succeeded.
- The secret value was not written to Automation job logs.
- SecretSet from the read-only workload identity was denied with Forbidden.
- Denied activity was visible in Log Analytics.
- A Key Vault security alert fired in Azure Monitor.
- Secret rotation succeeded without a runbook code change.

10. Resume Bullets

- Built an Azure secrets-management workflow using Key Vault, Microsoft Entra managed identities, Azure Automation, and RBAC, eliminating stored credentials from PowerShell automation.
- Implemented and validated least-privilege access by permitting automated SecretGet operations while blocking unauthorized SecretSet operations and verifying denials through Key Vault audit logs.

- Developed KQL-based monitoring and Azure Monitor alerting for unauthorized Key Vault activity, integrating Log Analytics with action-group notifications and validating secret rotation.

11. My Analysis

I built an Azure Key Vault PAM lab where an Azure Automation workload authenticates using a managed identity instead of stored credentials. I scoped the workload to Key Vault Secrets User, validated that it could retrieve a secret but could not modify one, and confirmed the denied operation in Key Vault audit logs. I then used Log Analytics and KQL for investigation and Azure Monitor for alerting. I also rotated the secret and verified the automation continued working without changing the runbook.

12. Skills

Azure Key Vault • Microsoft Entra ID • Managed Identity • Azure RBAC • Least Privilege • Secrets Management • Credential Rotation • Azure Automation • PowerShell • Log Analytics • KQL • Azure Monitor • Security Monitoring • IAM/PAM Control Validation